

Industrial Security (Bachelor)

Solution Sheet – Section 01

Introduction to Industrial Security

How to use these solutions

Each solution gives a model answer a tutor can read aloud, followed — where useful — by a short rubric hint. For open-ended exercises, award full marks for any answer that hits the listed key points; the wording will vary.

Solution

Exercise 1.1 – Classify the System

1. **IT.** A classical OLTP/OLAP workload. No coupling to a physical process; failure means data unavailability or financial misstatement, not a safety event. The decisive criterion is the absence of any actuator path.
2. **IIoT (hybrid).** The pitch controller is hard real-time OT (a wrong setpoint can overstress the blade or trip the turbine), but the cloud-bound MQTT stream creates an IT-side dependency. Treat the controller as OT for safety, and the MQTT broker / cloud account as an IT-adjacent ingress to be hardened.
3. **OT (or OT-adjacent / Purdue Level 2).** The workstation runs Windows but holds the signed engineering project. It is the highest-value pivot on the plant network — Stuxnet and TRITON both abused exactly this class of host. Classify as OT for protective purposes.
4. **IIoT.** The sensor sits on a rotating machine (OT), but its data path is straight into an IT data lake. The risk lives in the gateway and the topic ACLs as much as in the sensor itself.
5. **Hybrid (medical IIoT).** The pump is a safety-critical actuator, but its setpoints come from a wireless drug library and a barcode lookup — so an IT compromise rewrites a physical dose. The 2015 Hospira / Symbiq advisories (FDA, ICS-CERT ICSMA-15-161-01) are the canonical case.

Rubric. Full marks for any answer that (a) names the right bucket and (b) cites *coupling to a physical process* or *failure mode in atoms* as the decision criterion. Half marks for the bucket alone.

Solution

Exercise 1.2 – CIA Re-ordered, Concretely

1. Example: a SCADA alarm bus encrypted with a key whose rotation has failed. The operator at the HMI loses visibility on a runaway exotherm because the alarm packets cannot be decrypted in time; the strict confidentiality control has blocked the integrity / availability path. Other accepted answers: a TLS handshake timing out on a 4–20 mA-to-MQTT gateway during a control loop; a mandatory MFA prompt blocking an operator from acknowledging a trip.
2. Example: pharmaceutical batch recipes, semiconductor process recipes, generator dispatch curves in a deregulated market, secret coagulant dosing tables. Loss of confidentiality here

either erodes competitive advantage or, worse, enables a precisely targeted physical attack (an attacker who knows your set-points can manipulate them invisibly).

3. Sample charter sentence: *“In every plant we operate, the continuous safe operation of the physical process takes precedence over the confidentiality of operational data. Cryptographic and authentication controls in safety-relevant paths must fail in a mode that preserves operator awareness, alarm delivery, and manual override — never in a mode that blocks them.”*

Rubric. Award full marks for part (1) only if the answer names a specific control whose enforcement causes the harm (not just “encryption is bad”). For part (3), the policy must be operational, not aspirational: “cryptographic controls fail-open in the safety path” is the load-bearing phrase.

Solution

Exercise 1.3 – “Just Install Antivirus on the PLC” The auditor has confused a PLC with a Windows endpoint. A PLC (e.g. Siemens S7-1500, Rockwell ControlLogix, Schneider M580) runs a proprietary real-time firmware on a non-x86 SoC; there is no operating system in the Windows sense, no agent API, and no spare CPU budget for a scanner. Even on Windows-based HMIs and engineering workstations, vendors gate antivirus to a tested whitelist — running Defender with default heuristics has crashed control hosts (multiple Siemens and Rockwell advisories on antivirus interaction). The right answer to the auditor’s intent (*catch malicious code touching the bottling line*) lives in the *network* and on the *engineering workstation*, not on the controller. Two compensating controls: (a) a passive ICS network monitor (Claroty, Nozomi, Dragos, or open-source Malcolm) span-ported at the cell/area switch in Purdue Level 2/3, alerting on unsolicited Step7 or EtherNet/IP writes; (b) application-allow-listing (e.g. Microsoft AppLocker or a vendor-supported product such as McAfee Application Control) on the engineering workstation, plus disabling USB and locking the workstation in the MCC cabinet. Together these catch the threat the auditor was actually worried about without bricking the bottling line.

Rubric. Full marks require: (i) one technical reason the PLC cannot run AV, (ii) one risk that running AV would itself create, (iii) a network-side control, (iv) a host-side control on the EWS/HMI. Half marks for any two.

Solution

Exercise 1.4 – Read an Advisory: AA22-103A

1. The three named target families are: **Schneider Electric MODICON and MODICON Nano PLCs** (M340, M580, BMX, etc.), **OMRON Sysmac NEX/NJ PLCs**, and **Open Platform Communications Unified Architecture (OPC UA) servers**. The toolset (later publicly called *PIPEDREAM* / INCONTROLLER by Dragos and Mandiant) included modules for each.
2. The companion vulnerability is the ASRock motherboard driver CVE-2020-15368, but the safety-system call-out is **Schneider Electric’s** family — the advisory and the matching Dragos / Mandiant analysis specifically describe the toolkit’s reach into engineering workstations used to program Schneider PLCs (and Mandiant separately documented impact on Schneider’s safety-related stack). Accept any answer naming Schneider Electric.
3. The advisory was unusual because it disclosed a *pre-deployment* adversary capability: a complete, modular ICS attack framework was described before any confirmed victim. Historically (Stuxnet, TRITON, Industroyer) such tooling becomes public only after a successful attack; AA22-103A is one of the first cases where governments burned the toolkit to deny it.

Rubric. Full marks require the three target families in (1) and the unusualness point in (3). Tolerate vendor-name typos. If a student cites the unofficial names (PIPEDREAM, INCONTROLLER), accept them with a note that the advisory itself does not use those names.

Solution

Exercise 1.5 – Brewery CISO: 30 Minutes In A defensible 30-minute play looks like this. **First**, walk to the brewhouse with the plant manager and confirm with the operator on shift that the process is currently safe (tanks at expected levels, no active alarms, manual control available); if it is not, stop here and call for a controlled shutdown — safety dominates. **Second**, preserve evidence: take a photo of the HMI screen, ask the operator not to reboot anything, and have the shift log and the historian’s last 72 hours of trends exported before someone “tidies up.” **Third**, isolate the suspect HMI at the network layer (pull the cell-switch uplink to the corporate VLAN, or have IT block the relevant port) so any remote command-and-control loses its path while the PLC keeps running on its own logic. The action I would explicitly *not* take is to reboot the HMI, reimagine it, or run an antivirus scan on the spot — that destroys volatile evidence (RAM, current connections, recent process variables) and may itself trip a watchdog on the control loop. Triggering a forensic image of the HMI’s disk and engaging the vendor / a specialist DFIR firm comes immediately after the 30 minutes, not during them.

Rubric. The three actions must be ordered safety → evidence → containment. Award full marks for any reasonable ordering that respects that hierarchy and explicitly names the “do not” action. Common wrong first moves to mark down: “unplug everything,” “reboot the HMI,” “call the press,” “run Nessus.”

Solution

Exercise 1.6 – Compensating Controls Under Constraint A workable layered proposal: (1) place a **stateful industrial firewall with deep-packet inspection for Modbus/TCP** (e.g. a Hirschmann Eagle, Fortinet FortiGate Rugged, or Tofino Xenon) between Purdue Level 3 and the cell containing the Quantum PLC, with a strict allow-list of source IPs, function codes, and register ranges — this raises the bar against opportunistic and ransomware-tier actors who would otherwise reach the controller from the corporate network; (2) deploy **passive ICS network monitoring** (Claroty, Nozomi, Dragos, or Malcolm) on a span port at Levels 2–3, baselined for two weeks, alerting on any unsolicited write to coil/holding registers or any new Modbus master — this catches hackers and ransomware operators who slip past the firewall and gives forensic evidence to the SOC; (3) tighten **engineering-workstation hygiene** (Level 2): unique credentials, MFA on the jump host, USB blocked, application allow-listing, vendor remote access only through a brokered, recorded session (e.g. Cyolo, Claroty SRA, or a hardened bastion) — this is the control that actually raises the bar against capable / espionage-tier actors, because PIPEDREAM-class toolkits target exactly this host. Together the three controls bracket the threat without requiring the PLC to be touched.

Rubric. Full marks require three distinct controls at three different Purdue levels (or at least covering north–south, east–west, and host hygiene), each tied to a named threat actor tier. Half marks if controls are listed but the Purdue placement or threat-tier mapping is missing.

Solution

Exercise 1.7 – Compare Two Incidents

Dimension	Maroochy Shire (2000)	Colonial Pipeline (2021)
Attacker / motive	Vitek Boden, disgruntled ex-contractor; personal revenge after being denied a council job.	DarkSide ransomware affiliate; financial extortion.
Initial vector	Stolen SCADA radio equipment + insider knowledge of the sewage telemetry system.	Compromised credential for a legacy VPN account (no MFA) on the IT network.
Where harm landed	Directly in the physical process: 800,000 L of raw sewage released into parks and waterways over months.	In IT (billing system encrypted); the OT pipeline was shut down <i>precautionarily</i> by the operator, not by the attacker.
OT directly attacked?	Yes — attacker issued radio commands to pumping-station RTUs.	No — ransomware never reached the pipeline control system.
Key lesson	Insider threat + weak authentication on radio-linked OT is catastrophic; revoke credentials and rotate radio configs on departure.	IT/OT coupling can take OT down even when OT itself is untouched; MFA on every remote-access path is non-negotiable.

Primary sources. Maroochy: *R v. Boden*, Queensland Court of Appeal [2002] QCA 164; M. Abrams & J. Weiss, *Malicious Control System Cyber Security Attack Case Study — Maroochy Water Services*, MITRE / NIST, July 2008. Colonial: US Senate Committee on Homeland Security testimony by Joseph Blount, 8 June 2021; CISA / FBI Joint Cybersecurity Advisory AA21-131A, 11 May 2021; GAO-22-104746, 2022.

Rubric. Award full marks for any answer that distinguishes (c) and (d) correctly — the common student error is to assume Colonial’s OT was breached. The Maroochy insider angle and the Colonial MFA angle must appear in the lessons row.

Solution

Exercise 1.8 – Spot the Misconception

- Air-gap fallacy.** True air gaps are rare in practice (vendor laptops, USB drives, contractor jump hosts, cellular modems, OPC bridges all cross them) and even a real air gap leaves you blind to the attacker who is already inside. Stuxnet crossed an air gap into Natanz via USB in 2010; Shodan still indexes thousands of supposedly air-gapped HMIs every quarter (Dragos and Censys reports, annual). Monitoring is what lets you know whether the gap is intact.
- Absence-of-evidence fallacy.** OT environments are notoriously under-instrumented — without packet capture, syslog, or process historian baselines, “no incident” usually means “no detection.” The Dragos *Year in Review* reports consistently find that more than half of OT incident-response engagements discover an intrusion that pre-dates the customer’s awareness by months.
- Security-by-obscurity.** Modbus is a 1979 protocol with no authentication and no encryption; it is parsed by Wireshark out of the box, scripted by every off-the-shelf ICS toolkit (PLCScan, Metasploit modbusclient, pymodbus), and dissected by every commercial OT monitor. A “private serial loop” protects against a casual eavesdropper, not against an attacker with physical access or a converter at the gateway.

4. **Compliance-equals-security fallacy.** ISO 27001 certifies a management system, not a set of effective controls; the scope can exclude the OT environment entirely and the audit may never look at a PLC. Target Corporation was PCI-DSS compliant when it was breached in 2013, and Equifax was SOC 2 attested in 2017. Use certifications as a floor, not a ceiling.

Rubric. Full marks require the named fallacy + one concrete piece of evidence per item. Half marks for the refutation alone.

Solution

Exercise 1.9 – You Inherit an Undocumented Plant A defensible top-five (other orderings are acceptable if justified):

1. *“Which processes here can hurt someone if they go wrong — and where are the safety instrumented systems that prevent that?”* — answers the safety / IEC 61511 boundary and tells me which assets are non-negotiable to protect first.
2. *“Who — inside or outside the company — can reach a PLC remotely today, and through what path?”* — maps the actual attack surface (vendor VPNs, contractor laptops, cellular modems) and decides whether my first investment is a jump host or a firewall.
3. *“When was the last time anyone changed PLC logic, and how do you know what is running on each controller right now?”* — tells me whether the engineering workstation, project files, and code-signing posture are the real risk, or whether the unknowns live in the field.
4. *“What does the corporate-to-plant network connection look like physically and logically — is there a firewall, a DMZ, or just a switch?”* — decides whether the next budget line is segmentation or monitoring; both are useless if the boundary is a flat L2 link.
5. *“What incidents, near-misses, strange behaviours, or unexplained downtimes have happened in the last two years that nobody could explain?”* — mines the operators’ memory for the signals that no SIEM is collecting, and often surfaces existing compromises or chronic misconfigurations.

Rubric. Award full marks for any five questions that together cover: safety boundary, remote access, controller integrity, network architecture, and tribal knowledge. Mark down questions whose answer is a single number (“how many PLCs?”) unless they are explicitly tied to a decision.

Solution

Exercise 1.10 – Cost Reasoning: NotPetya at Maersk

1. The malicious M.E.Doc update gave NotPetya a foothold on a single Maersk subsidiary’s Windows host in Ukraine; from there the malware combined the EternalBlue SMBv1 exploit with Mimikatz-style credential theft to move laterally, and once it captured domain-administrator credentials it propagated through Maersk’s globally flat Active Directory in minutes — wiping about 4,000 servers and 45,000 workstations across more than 70 terminals worldwide. The two architectural properties that made the blast radius so large were (a) a single, globally flat AD forest with reusable domain-admin credentials, and (b) unpatched SMBv1 still enabled on Windows hosts months after MS17-010. The recovery only succeeded because a domain controller in Lagos / Tema was offline during the outbreak due to a local power cut, leaving one clean replica of the directory.
2. Maersk paid *no* ransom (NotPetya was a destructive wiper, not real ransomware — decryption was mathematically impossible). The ratio of direct ransom to total disclosed

loss is therefore *zero out of US\$ 250–300 M*. By contrast, Colonial paid roughly US\$ 4.4 M in ransom against a disclosed direct impact in the low hundreds of millions (and a regional fuel-supply shock that dwarfs that figure); the ransom is well under 5% of the loss. The board-level lesson is consistent in both cases: *the ransom is a rounding error; the loss is the downtime, the rebuild, and the regulatory follow-on*. Spend the next security euro on resilience, segmentation, and tested recovery — not on a “would we pay?” policy debate.

Rubric. Full marks require: NotPetya identified as a wiper (not ransomware), the AD-flatness + unpatched-SMBv1 pair, and the “ransom is a small fraction of loss” point in (2). Accept the Ghana / Lagos anecdote as a bonus but do not require it.